Aspectos Sociales de Ciberseguridad

Unidad 2. Gestión de Identidad

Licenciatura en Ingeniería de Ciberseguridad e Infraestructura de Cómputo

M.R.T. Martha Elizabet Domínguez Bárcenas

Contexto: La Red Corporativa Moderna

La red corporativa integra una amplia variedad de usuarios y entidades que requieren acceso seguro desde distintas ubicaciones.

Usuarios Humanos

- Empleados internos
- Clientes externos
- Contratistas y terceros

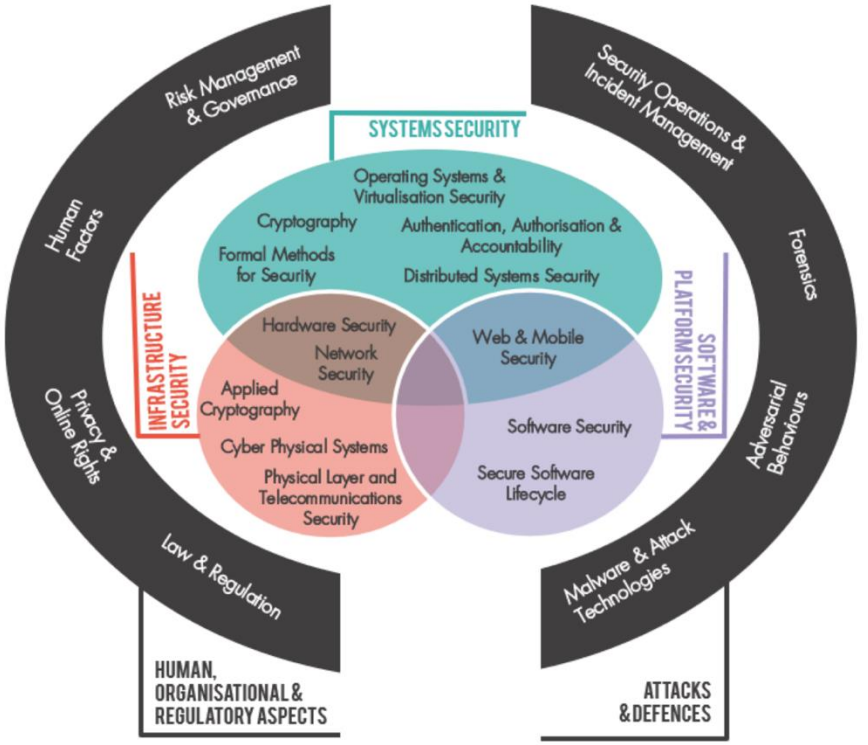
Usuarios No Humanos

- Agentes de IA
- Dispositivos IoT
- Endpoints corporativos
- Cargas de trabajo automatizadas

Necesidad crítica: acceso seguro por parte de usuarios distribuidos en distintas ubicaciones, a aplicaciones, recursos on-premises y en la nube.

Gestión de Identidad y Acceso (IAM)

Disciplina de ciberseguridad que se ocupa del aprovisionamiento y protección de identidades digitales y permisos de acceso a los usuarios de un sistema de TI.



Acceso Seguro

Facilita el acceso seguro a usuarios autorizados, garantizando que cada identidad tenga los permisos adecuados para sus funciones.

Bloqueo de Amenazas

Bloquea acceso no autorizado a atacantes externos, usuarios internos malintencionados e incluso a usuarios bienintencionados que hacen uso indebido de sus derechos de acceso.

Herramientas IAM

Permiten a las organizaciones crear y eliminar de forma segura identidades digitales, establecer y aplicar políticas de control de acceso, verificar usuarios y monitorizar la actividad de los usuarios.

Identidad Digital

Definición

Combinación de atributos y credenciales que representan a una persona o **entidad** en el mundo digital.

Conjunto de información vinculado a un usuario, máquina u otra **entidad** específica en un ecosistema de TI.

Componentes

- Nombres de usuario y contraseñas
- Direcciones de correo electrónico
- Datos biométricos
- Historial de navegación
- Perfiles en línea y otros datos identificadores

Funciones Clave

- Distinguir entre diferentes usuarios para el control del acceso.
- Seguimiento de actividades en el Sistema.
- Detección de fraude y prevención de ataques cibernéticos.

Rol en IAM

Las identidades digitales son la base de la **autenticación** y la **autorización**: procesos que utilizan los sistemas de TI para verificar a los usuarios y otorgarles acceso adecuado.

La identidad de una entidad está formada por sus **atributos** únicos que, juntos, forman un registro que verifica la identidad y los distingue de otras entidades.

Tipos de Identidades Digitales

Identidad Digital Humana

Puede incluir información como la edad, la licencia de manejar, el número de la Seguridad Social o datos biométricos como las huellas dactilares y los escaneos de reconocimiento facial.

Los seres humanos utilizan sus ID digitales para acceder a recursos, como hacer registro en una cuenta bancaria en línea o recuperar activos confidenciales en una red corporativa.

Identidad Digital de Máquinas

Corresponden a entidades no humanas, como aplicaciones, bots, nodos de Internet de las cosas (IoT) y otros dispositivos.

A menudo utilizan identificadores únicos, como certificados o token, para autenticarse y distinguirse.

Les permite acceder a ciertos recursos digitales, como una aplicación empresarial que obtiene datos confidenciales de una base de datos en la nube.

Identidades Federadas

Permiten a las personas usar sus identidades digitales en múltiples sistemas y servicios.

Son un tipo de identidad de usuario o máquina que no se limita a un sistema.

Ofrecen al usuario la comodidad de no tener que crear una identidad distinta para cada sistema.

Ejemplos: inicio de sesión con cuenta de Google o de Facebook en sitios que ofrecen otro tipo de servicio (Canva, Pinterest, Spotify, Mercado Libre, etc.).

Hacen posible la Federación de Identidades.

Métodos de Verificación y Casos de Uso

Métodos de Verificación de Identidad

Credenciales

Usuario y contraseña

Biometría

Huellas, reconocimiento facial

Certificados

Firmas y certificados digitales

Permiten reducir riesgos de fraude y evitar robos de identidad.

Casos de Uso Comunes

- **Servicios financieros.** Bancos, cooperativas de crédito, empresas de valores, aseguradoras, plataformas de intercambio de criptomonedas.
- **Atención médica.** Médicos y hospitales deben asegurarse de que las personas que reciben tratamiento y medicamentos son pacientes reales.
- **Gobierno.** Las agencias deben garantizar que los beneficios y servicios se presten a quienes tienen derecho a ellos.
- **Comercio electrónico.** Las empresas necesitan prevenir el fraude en las transacciones, garantizar procesamiento de pagos precisos y proteger los datos de los clientes.
- **Viajes, hostelería, telecomunicaciones y educación.** Necesitan proteger los datos en línea mediante verificación de identidad.
- **Operadores de juegos en línea.** Requieren comprobar la identidad de sus jugadores para prevenir fraude.

Pilares de la IAM

Administración

También conocida como "gestión del ciclo de vida de las identidades".

Proceso de crear, mantener y eliminar de forma segura las identidades de los usuarios. Implica asignar a cada usuario una identidad digital distinta: nombre, credenciales, puesto, derechos de acceso.

El sistema IAM almacena identidades, permite actualizar permisos y desaprovisionar usuarios. Puede ser manual o mediante enfoques de autoservicio.

Autenticación

Proceso que verifica que un usuario es quien dice ser.

El usuario envía credenciales ("factores de autenticación"): contraseña, escaneo biométrico (humano) o certificado digital (no humano).

El sistema IAM compara estas credenciales con la base de datos central.

Si coinciden, se concede el acceso.

Autorización

Proceso de conceder a los usuarios verificados los niveles adecuados de acceso a recursos.

RBAC (Control de Acceso Basado en Roles): privilegios basados en funciones de trabajo. Ejemplo: Analista junior ve configuraciones, administrador las modifica, CISO tiene acceso completo).

Principio del mínimo privilegio: los usuarios deben tener solo las licencias más bajas necesarias; los privilegios se revocan al completar la tarea.

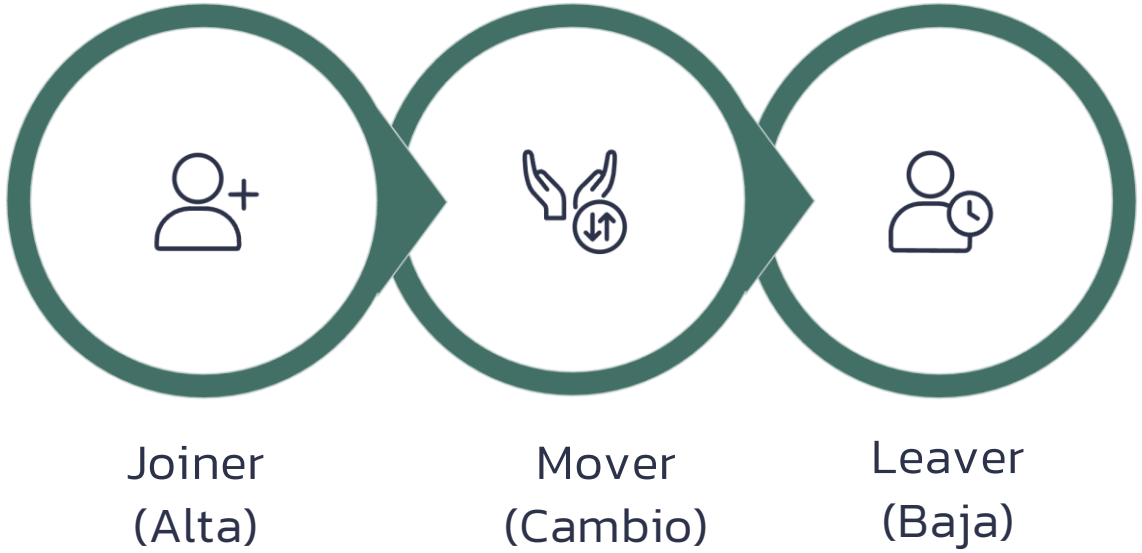
Auditoría

Garantiza que el sistema IAM y sus componentes funcionan correctamente.

Implica rastrear y registrar lo que los usuarios hacen con sus derechos de acceso para garantizar que nadie tenga acceso a nada que no deba y que los usuarios autorizados no abusen de sus privilegios.

Ciclo de Vida de la Identidad: Modelo JML

También conocido como **Modelo JML (Joiner, Mover, Leaver).** Rige las identidades de los usuarios y los derechos de acceso durante todo el tiempo que un empleado permanece en una organización. Proceso de gestionar el acceso cuando alguien se incorpora a la empresa, cambia de puesto o la abandona.



Joiner

Incorporación: creación de identidad, aprovisionamiento de acceso y asignación de roles para nuevos empleados, pasantes o contratistas.

Mover

Traslado: ajuste de permisos cuando un empleado cambia de puesto, equipo o responsabilidad dentro de la organización.

Leaver

Baja: revocación de acceso, recuperación de activos y generación de registro de auditoría al abandonar la organización.

Actividad

- **Por equipos de 3 personas:**
  - **Elegir una organización (educativa, de salud, gubernamental, etc.)**
  - **Desde el punto de vista de la ciberseguridad, analizar y proponer una lista de actividades a considerar en caso de una Alta, Cambio y Baja de un empleado de área de TI.**
  - **Entregar una matriz en la que se establezcan los responsables por cada actividad.**

Joiner: Alta o Incorporación

Nuevos empleados, pasantes o contratistas necesitan acceso a las cuentas y herramientas necesarias para desempeñar sus funciones. Esto implica varias fases:

01

Creación de Identidad

Registro en plataforma de RH (nombre, fecha de ingreso, jefe, departamento, ID, email personal).

Reglas de inicio de sesión (SSO, MFA, etc.).

Asignación de tipo de trabajador (tiempo completo, contratista, becario, etc.)

02

Preboarding (Preembarque)

Preparación de un paquete básico para cada departamento que incluya correo electrónico, chat y otros sistemas esenciales.

Solicitar los dispositivos adecuados, instalar las licencias de software necesarias.

03

Asignación de Roles y Grupos

Definición de roles según función, departamento y nivel de responsabilidad del nuevo usuario en el sistema.

04

Aprovisionamiento de Usuarios

Otorgar permisos de acceso a dispositivos, licencias de software, datos de la empresa y otros recursos organizativos.

05

Verificación y Revisiones de Acceso

Confirmación de que los accesos otorgados son correctos y se ajustan al perfil y necesidades del nuevo usuario.

Mover: Cambio o Traslado

Los empleados pueden cambiar de puesto, equipo o responsabilidad dentro de la organización, modificando sus funciones, por lo que se requieren cambios de acceso. Esto implica las siguientes tareas:

1 Seguimiento de Transferencias Internas

Actualización de roles, tickets de gestión de servicios de TI, notificación a gerentes.

2 Asignación de Nuevos Roles y Derechos

Revisa necesidades del nuevo usuario en cada aplicación y sistema.

3 Aprobación de Acceso Basada en el Riesgo

No todos los accesos requieren el mismo nivel de revisión.

Los sistemas críticos requieren verificaciones adicionales y aprobaciones explícitas.

Gestionar nuevas solicitudes de acceso (supervisores, equipo de TI).

4 Eliminación de Derechos de Acceso Previos

Conservar solo aquellos de los que se tenga una razón clara y específica.

Priorizar la revocación del acceso a sistemas sensibles, unidades compartidas, herramientas de colaboración y servicios en la nube antes de pasar a otras aplicaciones de bajo riesgo.

5 Aprovisionamiento de Nuevo Acceso

Considerar nuevo rol, departamento y ubicación del usuario.

6 Recertificación de Acceso Posterior

Revisar y validar los derechos de acceso.

Retirar el acceso a las aplicaciones que ya no se ajustan al nuevo puesto.

Desactivar las cuentas que solo estaban destinadas a ayudar durante la transición.

Leaver: Baja (1)

Personas que abandonan la empresa, ya sea por renuncia, finalización de contrato o despido. Se debe revocar el acceso rápidamente, recuperar los activos informáticos y dejar un registro claro de lo sucedido.

01

Activar Evento de Desvinculación

Registro de salida y motivo por parte de RH, supervisores o gerentes (ID, última hora de trabajo, nombre gerente, motivo).

Envío de información a equipos de TI y de Seguridad.

02

Desactivación de Cuenta

Buzones de correo, VPN y herramientas de comunicación.

Finalización de sesiones activas.

Cambio de contraseñas en cuentas compartidas.

03

Revocación de Acceso y Desaprovisionamiento

Revocar el acceso a todas las aplicaciones y sistemas utilizados.

Permisos de administrador y cuentas con privilegios.

Permisos en herramientas que manejan información confidencial (nómina, RH, registros de clientes).

Otras aplicaciones, unidades compartidas, espacios de trabajo y herramientas de proyectos anteriores.

Leaver: Baja (2)

04

Transferencia de Propiedad de Datos

Antes de eliminar las cuentas de forma permanente, transferir los datos importantes a las personas adecuadas.

Asignar nuevo propietario a carpetas compartidas, paneles de control, repositorios, cuentas de servicio, archivos y recursos en la nube.

Registrar qué se transfirió y a quién.

05

Recuperación de Licencias de Hardware y Software

Recopilación de computadoras portátiles, teléfonos, credenciales y cualquier otro equipo vinculado a la persona que se va.

Si el trabajador es remoto: enviar etiquetas de devolución, compartir instrucciones de envío y proporcionar una fecha límite clara.

Bloquear el dispositivo después de la última jornada laboral y borrar los datos tras iniciar sesión.

Recuperar las licencias de software una vez completada la transferencia de datos.

06

Generación del Registro de Auditoría

Registro detallado de cada acción a lo largo de todo el ciclo de vida de la identidad:

- cuándo se produjo el desencadenante de la baja,
- cuándo se deshabilitaron las cuentas,
- qué aplicaciones se eliminaron,
- quién aprobó las excepciones.

Guardar informes de todos los sistemas en un solo lugar.

07

Confirmación de Baja

Verificar que el usuario no tenga inicios de sesión activos, sesiones abiertas ni roles residuales. Escaneo para detectar cuentas vinculadas a su correo electrónico, nombre de usuario o ID de empleado.

Verificación de claves de acceso no funcionales.

Pedir confirmación de transferencia de datos y el estado de devolución de dispositivos.

Cuatro pilares de la gestión del ciclo de vida de la identidad

1

Aprovisionamiento

- Establece la identidad y otorga el acceso básico.
- Creación de cuenta, definición de rol inicial y asignación de permisos.

2

Gestión y modificación de accesos

- Cambio de rol de una entidad
- Adaptación de permisos
- Revisión y actualización contínua de derechos de acceso, de acuerdo con el principio del mínimo privilegio.

3

Seguimiento y auditoría

- Visibilidad contínua de todas las actividades de la entidad y solicitudes de acceso
- Auditorías periodicas (cumplimiento normativo, cuentas fantasma, usuarios inactivos con privilegios excesivos)

4

Desabastecimiento

- Eliminación sistemática del acceso a una entidad, cuando abandona la organización

Autenticación de personas

Verificación de identidad y control de acceso seguro

Factores de Autenticación Tradicionales vs. Autenticación Sin Contraseña (Passwordless)

Factores de Autenticación Tradicionales

Factores de Conocimiento

- Cualquier factor de autenticación que se base en un secreto que el usuario conoce.

– Contraseñas

- Método más común de autenticación
- Objeto de robo a través de phishing o malware
- Adivinables a través de ataques de fuerza bruta
- Disponibles en la dark web
- En 2025, el robo de cuentas válidas fue uno de los vectores de ataque presentes en el 32% de los ataques (IBM X-Force Threat Intelligence Index 2025)

– Preguntas de seguridad

- Descubribles mediante Ingeniería Social o espionaje en redes sociales.

Factores de Autenticación Sin Contraseña (Passwordless)

- Utilizan cosas que son más difíciles de robar o falsificar:
  - Token de hardware
  - Claves de acceso criptográficas
  - Datos biométricos
  - Aplicaciones de autenticación
  - No se pueden falsificar fácilmente

Proceso de Autenticación Típico

Los usuarios prueban su identidad ofreciendo evidencia de que son quien dicen ser, a través de un factor de autenticación.



Factores de conocimiento

Algo que se sabe.



Factores de posesión

Algo que tiene el usuario (contraseña de un solo uso (OTP), clave criptográfica privada).



Factores inherentes

Algo que define al usuario (datos biométricos).



Factores de comportamiento

Algo que hace el usuario (patrones de escritura, gestos específicos con el mouse).

Claves de Acceso (Passkeys) y FIDO/FIDO2

¿Qué son las Claves de Acceso?

- Basadas en criptografía de clave pública
- Implementadas de acuerdo con estándares FIDO o FIDO2

Fast Identity Online (FIDO)

- Conjunto de estándares abiertos para la autenticación sin contraseña para sitios web, aplicaciones y servicios en línea.
- Reemplaza las contraseñas tradicionales con claves criptográficas llamadas "passkeys"
- Desarrollados por la FIDO Alliance: consorcio de gobierno, empresas y empresas tecnológicas, incluidas IBM, Apple, Amazon, Microsoft, PayPal, entre otras.
- Funcionan generando un par de claves criptográficas: una clave pública compartida con el servicio y una clave privada almacenada en el dispositivo del usuario.
- La clave privada nunca se comparte con el servicio.
- La clave privada está protegida mediante un PIN o un método de verificación biométrica.

Ejemplo de uso: plataformas como Amazon o Mercado Libre.

Flujo de Autenticación

01

El servicio envía un desafío al dispositivo del usuario.

02

El usuario desbloquea su clave privada y la utiliza para firmar el desafío.

03

El desafío se envía de vuelta al servicio, que utiliza su clave pública para verificar que el desafío se firmó con la clave privada correspondiente.

04

Se concede acceso al usuario.

fido ALLIANCE

Factores Biométricos

Características

- Se basa en las características físicas del usuario.
- Se consideran seguros porque no se pueden robar ni falsificar con facilidad.
- Se consideran fáciles de usar porque los usuarios no necesitan hacer nada especial para ingresar credenciales biométricas.

Origen

- Bio (vida) + metric (medir) → Medición y análisis estadístico de datos biológicos.
- Datos biométricos no son transferibles
- Supuesto: la característica elegida identifica de forma única a la persona



Desafíos

- Falsos positivos/negativos
- Requisitos muy estrictos – Alta probabilidad de rechazo
- Requisitos muy laxos – Alta probabilidad de validaciones erróneas
- Almacenaje seguro: Copias del dato biométrico almacenadas como bits en una plantilla. Requiere protección.
- La autenticación implica proporcionar copia del dato biométrico que se digitaliza y se compara con la plantilla.

Tipos de Biometría

Biometría Estática

Métodos biométricos fisiológicos, dependen de características humanas fijas.

- Reconocimiento de huellas dactilares
- Lectura de geometría de la mano
- Lectura de iris
- Exploración de la retina



Biometría Dinámica

Métodos biométricos de comportamiento, relacionados con una determinada acción del usuario (hábito de comportamiento).

- Dinámica de firmas
- Reconocimiento del habla



Requisitos Generales de un Método Biométrico

Universalidad

Cada persona debe tener la característica.

Singularidad

Dos personas no deben tener la misma característica.

Permanencia

La característica no debe cambiar ni ser alterada.

Coleccionabilidad

La característica debe ser medible.

Rendimiento

La característica debe poder medirse en términos de precisión, velocidad, robustez y recursos necesarios.

Aceptabilidad

La característica debe ser aceptable por el público.

Elusión

No debería ser fácil engañar al sistema.

Inhibidores de Uso Generalizado y Componentes de un sistema biométrico

Inhibidores de su uso generalizado

- Preocupación por la privacidad del usuario.
- Escasa aceptación por parte del público.
- Percepción de amenaza para la salud:
  - Escaneo de retina (afectación al ojo)
  - Contacto directo con el sensor de huellas (poco higiénico).
- Rastreo de usuarios.
- Compromiso de información confidencial.
  - Ejemplo: imagen de retina puede reflejar enfermedades cardiovasculares.

Componentes

- Hardware (sensores): Requieren alta fiabilidad.
- Software: Requiere bajos porcentajes de error.
- Almacenamiento.
- Transmisión.



Contraseñas de un Solo Uso (OTP)

- Se consideran factores de posesión, no de conocimiento.
- No son secretos de larga duración.
- Lo que verifica a la persona es la posesión de la aplicación de autenticación registrada (p.ej., número de teléfono)
- Válidas solo por un breve período.
- Cada vez que un usuario necesita iniciar sesión en un servicio, genera una nueva OTP.

Formas de generar OTP

- Usar una clave de seguridad por hardware para generar OTP con solo pulsar un botón.
- Usar una aplicación de autenticación basada en teléfonos inteligentes, que crea continuamente OTP basadas en tiempo (TOTP) de corta duración para servicios emparejados.
- Usar mensajes de texto SMS para recibir OTP de un servicio de autenticación.

TOTP y HOTP

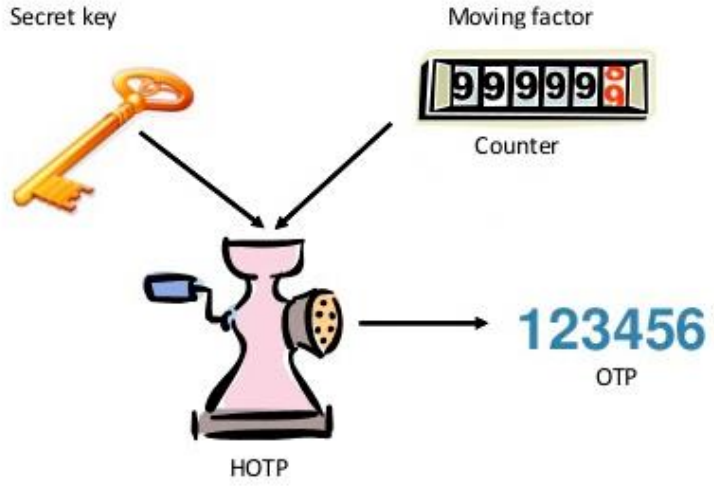
TOTP: Time-Based One-Time Password

- Algoritmo secreto que genera códigos utilizando la hora actual.
- Cada que se inicia la creación de un TOTP, se genera un algoritmo único y secreto.
- El servidor guarda el secreto y lo utiliza para generar los códigos TOTP.
- Usuario escanea código QR (adquiere el secreto)
- Herramienta de autenticación calcula exactamente el mismo código que el servidor.
- Los códigos cambian cada 30-60 segundos
- Usuario introduce código, que coincide con el del servidor.



HOTP: Hash-Based One-Time Password

- Contraseña de un solo uso basada en hash.
- Utiliza un Código de Autenticación de Mensajes basado en Hash (HMAC).
- HMAC cuenta el número de veces que se solicita un código y lo utiliza para calcular el nuevo código.
- El código cambia cada que se solicita.



Tokens de Hardware y Enlaces Mágicos

Tokens de Hardware

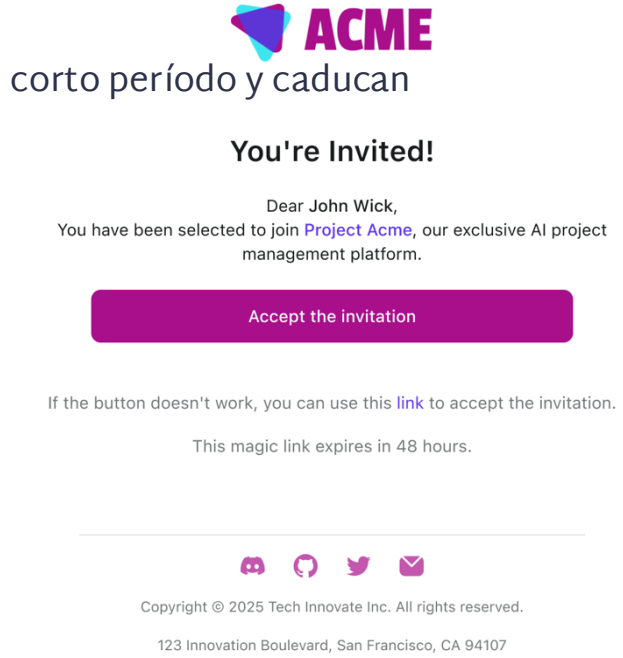
- Dispositivos dedicados, a menudo en forma de adaptador (dongle) USB.
- Algunos tokens de hardware utilizan OTP:
  - Crean nuevas OTP regularmente, como una aplicación de autenticación.
  - Generan OTP bajo demanda cuando el usuario presiona un botón.
- Otros tokens transmiten automáticamente la información de autenticación a un servicio cuando se conecta a un dispositivo.
- Puede ser costoso emitir una clave para cada empleado o usuario de un servicio.





Enlaces Mágicos (Magic Links)

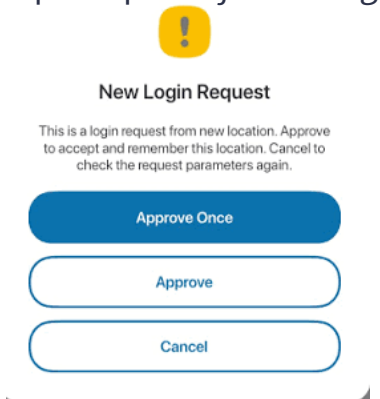
- Enlaces especiales que contienen tokens de autenticación.
- El usuario se registra con un correo electrónico o número de teléfono.
- Cuando el usuario quiere iniciar sesión:
  - Solicita un enlace mágico.
  - El servicio envía el enlace al correo electrónico o dispositivo móvil registrado. Cuando el usuario hace clic, es redirigido al servicio al que desea acceder.
- Especie de factor de posesión: se prueba la posesión de la cuenta de correo o número telefónico.
- Los enlaces mágicos son válidos solo por un corto período y caducan automáticamente después de un uso.



Notificaciones Push y Códigos QR

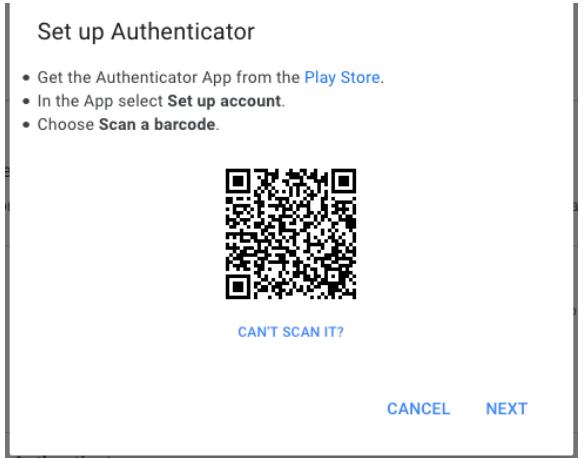
Notificaciones Push

- Funciona de forma similar a los enlaces mágicos.
- Envía notificaciones push al dispositivo móvil previamente registrado del usuario cuando intenta iniciar sesión en un servicio.
- El usuario debe tocar "aprobar" (o algún equivalente) en la notificación push para obtener acceso.
- Susceptibles a ataques conocidos como "avalanchas de notificaciones push" (también llamadas "fatiga MFA", "bombardeo MFA" o "spam de instrucciones"):
  - Un actor de amenazas navega hasta el servicio que quiere vulnerar, ingresa el ID de usuario de su objetivo y solicita repetidamente autenticación mediante la notificación push.
  - El objetivo es abrumar al dispositivo de la víctima con una avalancha repentina de notificaciones, de modo que esta apruebe alguna por accidente o simplemente para que dejen de llegar.



Códigos QR

- Los inicios de sesión muestran un código QR.
- El usuario escanea el código, generalmente con una aplicación de autenticación o una aplicación específica del servicio al que está accediendo, y esto lo registra.
- Mecanismo básico: transferencia de sesión.
  - El código escaneado tiene un token de corta duración que representa la sesión pendiente y no autenticada.
  - El usuario escanea este código con su dispositivo móvil previamente registrado y autenticado.
  - El dispositivo móvil aprueba la sesión.
  - El servidor web vincula la sesión aprobada a la identidad del usuario, y el usuario obtiene acceso al servicio en su computadora portátil.



Autenticación Multi-Factor (MFA)

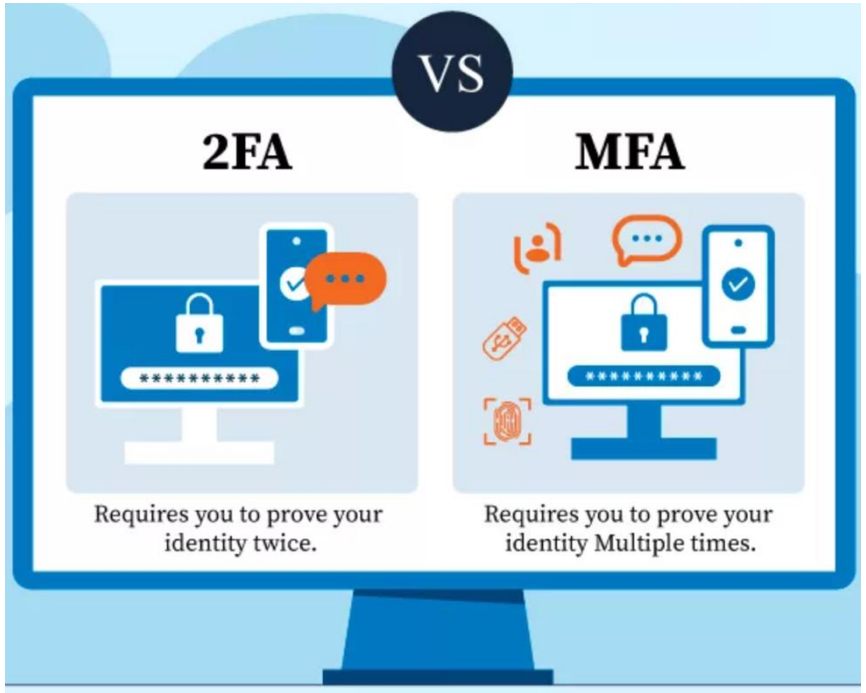
Sistema de seguridad de varias capas que ayuda a verificar un usuario, una aplicación o un dispositivo a través de varios identificadores. Requiere al menos 2 factores.

Factor 1

Usuario + contraseña — Algo que se sabe (factor de conocimiento).

Factor 2

Algo que se tiene (físico o digital) o algo que se es (dato biométrico) — factor de posesión o factor inherente.



Actividad

Por equipos de máximo 3 personas:

- Elegir un método de autenticación passwordless e investigar su rendimiento con base en las siguientes tres variables:
  - **Tiempo de acceso**
  - **Fricción del usuario**
  - **Resistencia al phishing**.

- Compartir conclusiones en carpeta de Teams: PASSWORDLESS

Identidad de dispositivos

Identificación, autenticación y control de acceso de dispositivos

Identidad de Dispositivos

Necesidad de Identificar y Autenticar Dispositivos

- Amplio uso de:
  - Dispositivos del Internet de las Cosas (IoT).
  - Dispositivos de Tecnología Operativa (OT).
    - Supervisan, controlan y operan procesos físicos, maquinaria y equipos industriales.
  - Dispositivos utilizados para el intercambio de datos sensibles (pacientes, pagos, energía, entre otros).

- Ataques a los dispositivos que manejan estos datos pueden provocar pérdidas económicas y daños a la reputación.

- Verificación de identidad para mitigar el riesgo de accesos no autorizados.

Superficies de Ataque

Dispositivos

Puertos y conexiones abiertos cuando no está en uso

Intercambio de datos en la red (Man-in-the-Middle)

Servidores o aplicaciones en la nube

Autenticación de Dispositivos

Identificador

- IMEI. Identidad Internacional de Equipos Móviles, asociada al SIM (Suscriber Identity Module)

Certificados digitales x.509

TPM (Trusted Platform Module)

MTLS o TLS mutuo

Certificados Digitales x.509

- Archivo digital que vincula un par de claves criptográficas (una clave pública y una clave privada) con la identidad de una entidad (sitio web, organización, persona, dispositivo).
- Utiliza Infraestructura de Clave Pública (PKI, por sus siglas en inglés). Sistema de hardware, software, políticas y estándares que trabajan en conjunto para gestionar los certificados.
- Involucra a una Autoridad de Certificación (CA): entidad de confianza que garantiza la identidad de la entidad y emite un certificado de clave pública (firma con una clave que proporciona una cadena de confianza al certificado).

Componentes de un Certificado Digital

- Nombre de la entidad (o dominio, en el caso de sitios web)
- Clave pública de la entidad
- Nombre y Firma digital del emisor (CA)
  - **Firma digital**: proceso matemático que permite verificar la autenticidad e integridad de un mensaje, creado mediante un algoritmo criptográfico específico.
- Número de serie único
- Periodo de validez
- Algoritmo criptográfico utilizado para las claves
- El certificado es firmado con la clave privada de la CA

Tipos de Certificados Digitales

- Certificados TLS/SSL
- Certificados de Firma de Código
- Certificados S/MIME
- Certificados de Cliente
- Certificados Digitales Educativos

TLS/SSL: Seguridad para Sitios Web

TLS (Transport Layer Security) y su predecesor SSL (Secure Sockets Layer) son protocolos que cifran el tráfico web entre el navegador del usuario y el servidor.

Indicadores de su uso: **'https'** en la URL y el **ícono de candado** en la barra de direcciones del navegador web. Ejemplo: Banco en línea, tienda e-commerce.



Proceso TLS/SSL

01

El navegador solicita identidad del servidor.

02

El servidor responde con certificado TLS/SSL.

03

El navegador comprueba certificado con su lista de CA de confianza.

04

Si el certificado es confiable, el navegador utiliza la clave pública del servidor para crear y enviar una clave de sesión secreta.

05

El servidor usa su clave privada para descifrar ese mensaje.

06

Se establece un canal de cifrado seguro durante toda la sesión.

Tipos Especializados de Certificados TLS/SSL

Wildcard. Para múltiples subdominios

Ejemplo: *.miempresa.com.

Protegen un dominio principal y todos sus subdominios con un único certificado.

SAN/Multidominio.

Ejemplo: miempresa.com, tienda.miempresa.es.

Subject Alternative Name (SAN).

También llamados certificados multidominio.

Permiten proteger varios nombres de dominio distintos (no necesitan compartir la misma raíz).

Validación Extendida (EV).

Ejemplo: Sitio Web de entidad financiera regulada o algún organismo público.

Para máxima confianza institucional

Su emisión exige un proceso de validación rigurosa de la identidad de la organización.

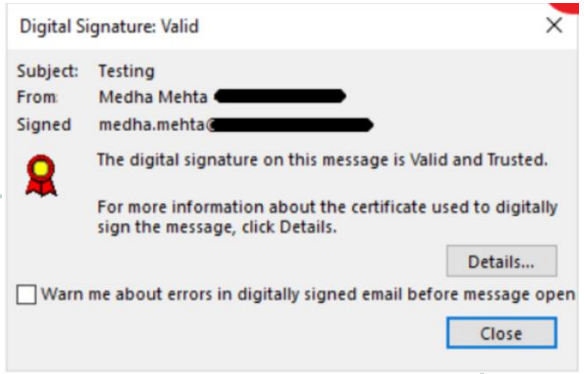
Tipos de Certificados Digitales (continuación)



Certificados de Firma de Código. Para autenticidad de software

- Ejemplo: Actualización de Windows, App móvil.
- Permite prevenir la distribución de malware disfrazado de software legítimo.
- Para confirmar la autenticidad del software o de los archivos descargados a través de Internet.
- El desarrollador o editor firma digitalmente el software para confirmar que es genuino para los usuarios que lo descargan (hash firmado).
- Garantiza la identidad del creador y la integridad del archivo.
    - Un paquete firmado incluye: el software del editor, un certificado de firma de código (identidad y clave pública del editor, así como firma del CA) y una firma digital (hash del software firmado con la clave privada del editor).
    - Cuando el usuario obtiene el paquete firmado, utiliza la clave pública del certificado para revelar el hash de la firma digital.
    - Compara el hash de la firma digital contra el hash calculado. Si coinciden, significa que el software no ha sido manipulado.
- Casos de uso: revisiones de software, pruebas, productos de dispositivos IoT, aplicaciones móviles, firmware, mensajes XML, scripts, contenedores e imágenes.

Tipos de Certificados Digitales (continuación)



Certificados S/MIME. Para cifrado de correo electrónico

- Ejemplo: Correo corporativo confidencial.
- Secure/Multipurpose Internet Mail Extension
- Protegen las comunicaciones por correo electrónico mediante dos mecanismos complementarios: la firma digital del mensaje (autenticidad) y el cifrado del correo (confidencialidad).



Certificado de Cliente. Para dispositivos y usuarios

Ejemplo: Acceso a VPN empresarial (el cliente requiere un certificado en el dispositivo del empleado).

Identificación digital que permite distinguir a un usuario de otro usuario, o a una máquina de otra.

Autentica al cliente ante el servidor. La identidad queda vinculada a un certificado criptográfico que no puede ser adivinado ni reutilizado.



Certificados Digitales Educativos. Para diplomas y certificados digitales

Ejemplo: Título universitario, certificación profesional.

Credencial digital firmada criptográficamente por la institución emisora.

TPM (Trusted Platform Module)

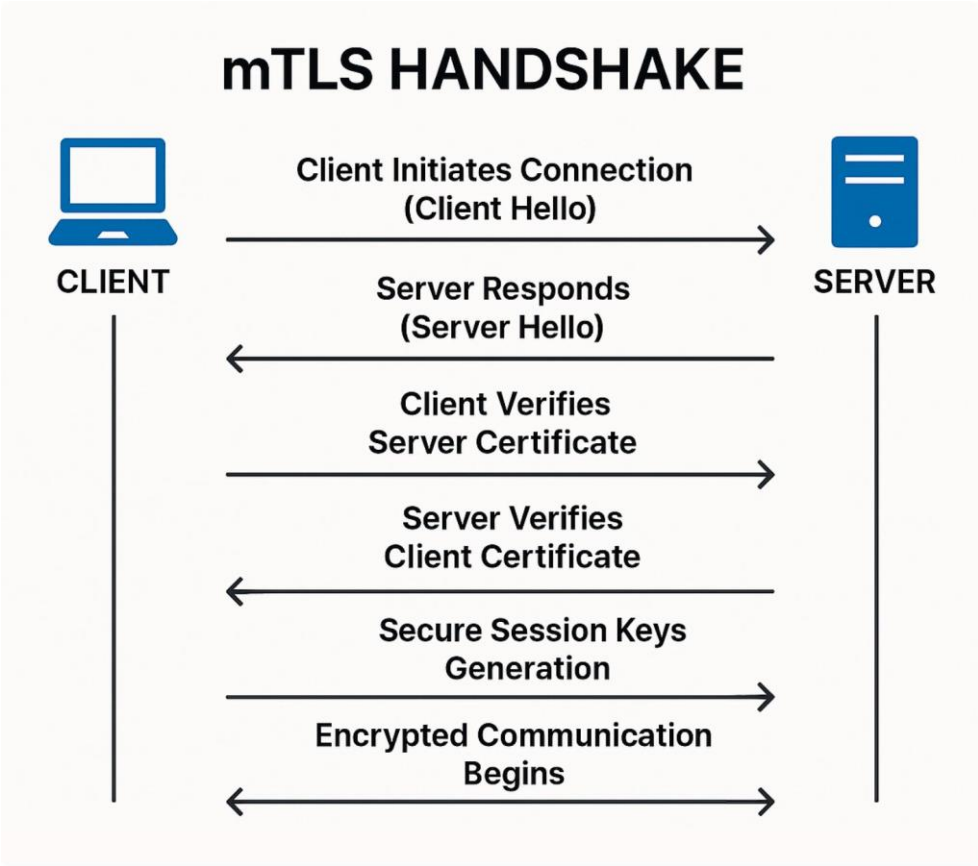
Módulo de Plataforma Segura



- Proporciona funciones de seguridad basadas en hardware.
- Chip que incluye un procesador criptográfico seguro para realizar operaciones criptográficas.
- Incluye varios mecanismos de seguridad físicos para que sea resistente a alteraciones; el software malintencionado no puede alterar las funciones de seguridad del TPM.
- El chip genera, almacena y limita el uso de claves criptográficas.
- Permite la autenticación de dispositivos mediante una clave RSA única del TPM, grabada en el chip.
  - RSA es el algoritmo de criptografía asimétrica utilizado para generar una clave pública y una privada.
- Permite medir la integridad del sistema, la creación y el uso de claves.
- Permite aplicación de medidas de seguridad durante el proceso de arranque de un sistema.
- Protege contra ataques de diccionario, al limitar el número de intentos de autorización incorrectos.
- El módulo debe ser soportado por el sistema operativo.

MTLS o TLS Mutuo

- Transport Layer Security (TLS) es el estándar de facto para el cifrado de las comunicaciones por Internet.
- Permite que los certificados digitales actúen como herramientas criptográficas para autenticar las identidades de personas, organizaciones o dispositivos.
- Los certificados TLS se centran principalmente en el servidor; sin embargo, también admite autenticación de clientes a través de TLS mutuo.
- Reduce la posibilidad de accesos no autorizados.
- Capa adicional de seguridad.



Control de Acceso a la Red (NAC)

Proceso de restringir el acceso de usuarios y dispositivos no autorizados a una red informática corporativa.
Solución de seguridad que aplica políticas a los dispositivos y usuarios que se conectan a una red.

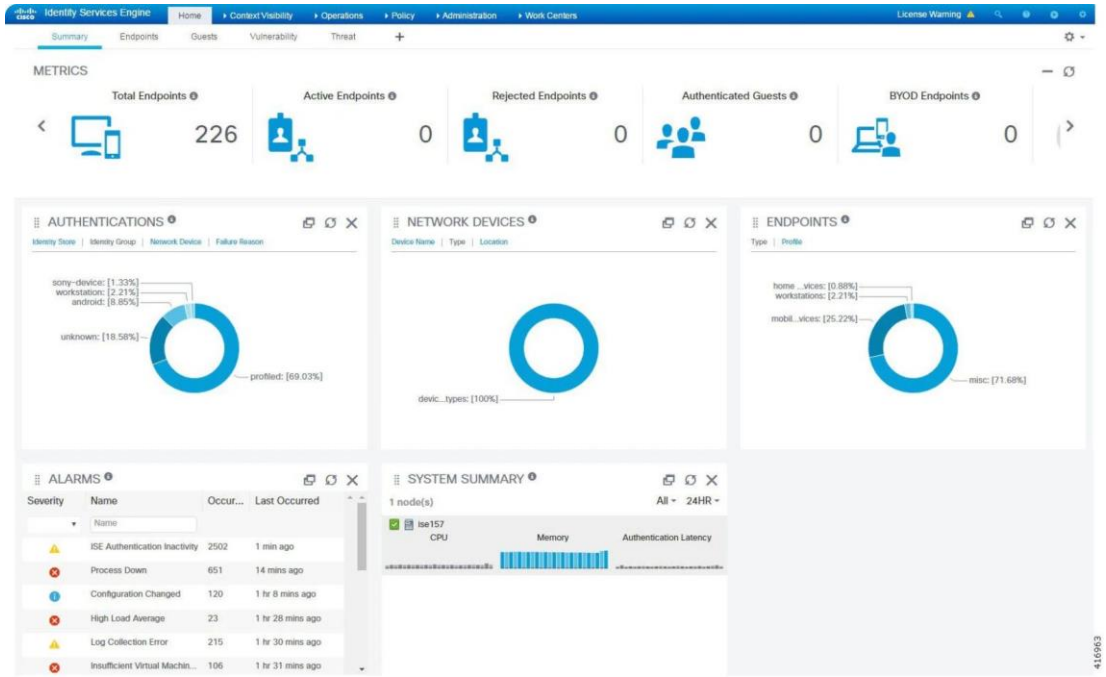
Tipos de Dispositivos Considerados

- De usuario final
- Dispositivos médicos
- Dispositivos IoT
- Dispositivos BYOD
- Impresoras y cámaras
- Entre otros

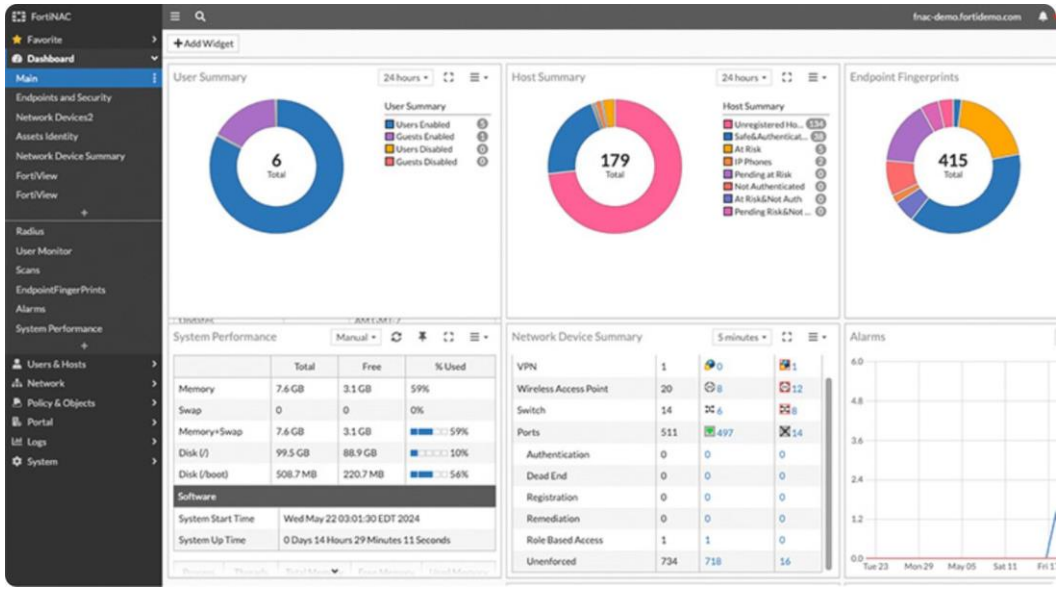
Funciones del NAC

- Controla el acceso para aumentar la visibilidad y reducir el riesgo.
- Valida la identidad de quién o qué se conecta y verifica el cumplimiento de la política de seguridad.
- Decide si concede, restringe o bloquea el acceso (cuarentena, acceso restringido o denegación).
- Permite gestionar políticas, perfiles, inventario de usuarios/dispositivos, redes para invitados, autenticación (MFA, certificados, MAC) e integración con otras herramientas de seguridad.
- Incrementa el control de acceso, especialmente en entornos con políticas BYOD.

Ejemplos de Soluciones NAC



Cisco Identity Services Engine (ISE)



Fortinet FortiNAC

Confianza Cero (Zero Trust)

Conjunto de paradigmas de ciberseguridad en evolución (NIST SP 800-207).

Asume que **no hay confianza implícita concedida** a activos o cuentas de usuario basada únicamente en su **ubicación física o de red** (es decir, redes de área local frente a Internet) o basada en la **propiedad de los activos** (propiedad de la empresa o personal).

Implica **autenticación y autorización** de sujetos y dispositivos, antes de acceder a un recurso de la empresa.

Principio fundamental: **“Nunca confíe, siempre verifique”**

Es una respuesta a las tendencias de las redes empresariales que incluyen usuarios remotos, dispositivos personales (BYOD) y activos basados en la nube que no se encuentran dentro de los límites de una red propiedad de la empresa.



Cambio de Enfoque: Zero Trust

- Se centra en **proteger los recursos** (activos, servicios, flujos de trabajo, cuentas de red, etc.), **no los segmentos de red** (perímetro físico).

- Parte de la base de que el **atacante está presente en el entorno** y que el ambiente de la compañía no es diferente (o no es más confiable) a cualquier otro que no sea de la organización.

- Se deben **analizar y evaluar continuamente** los riesgos para los activos y actividades corporativas y luego definir protecciones para mitigarlos.

- La **implementación de Zero Trust es gradual**: implica cambios en los procesos y soluciones tecnológicas, evaluación de la confianza en cada transacción, análisis y evaluación continua de solicitudes de acceso de forma dinámica, y considera la "necesidad de acceso".

Tipos de de Modelos de Seguridad Zero Trust (1)

- **Confianza cero basada en la identidad**
  - **Se** basa en el principio de **verificación estricta de la identidad**.
  - Cada usuario o dispositivo es autenticado y autorizado antes de acceder a cualquier recurso
  - Se basa en la autenticación multifactor, los controles de acceso y los principios de privilegio mínimo.

- **Confianza cero basada en la red**
  - **S**e centra en **proteger el perímetro de la red** dividiendo la red en segmentos más pequeños.
  - Su objetivo es **reducir la superficie de ataque** limitando el acceso a recursos específicos solo a usuarios autorizados.
  - Emplea tecnologías como cortafuegos, VPN y sistemas de detección y prevención de intrusiones.

- **Confianza cero basada en datos**
  - **Su ob**jetivo es **proteger los datos confidenciales** cifrándolos y limitando el acceso a los usuarios autorizados.
  - Usa la clasificación y etiquetado de datos, prevención de pérdida de datos y tecnologías de cifrado para proteger los datos en reposo, en tránsito y en uso.

Tipos de de Modelos de Seguridad Zero Trust (2)

- **Confianza cero basada en aplicaciones**
  - Se centra en **proteger las aplicaciones y sus datos asociados**.
  - Asume que todas las aplicaciones no son de confianza y deben verificarse antes de acceder a datos confidenciales.
  - Usa controles como protección en tiempo de ejecución y uso de contenedores, para proteger contra ataques como la inyección de código y el malware.

- **Confianza cero basada en dispositivos**
  - Protege los dispositivos en sí (por ejemplo, teléfonos inteligentes, computadoras portátiles y dispositivos IoT).
  - Asume que los dispositivos pueden ver comprometidos y deben **verificar antes de acceder a datos confidenciales.**
  - Usa controles de seguridad a nivel de dispositivo, como protección de endpoint, cifrado de dispositivos y capacidades de borrado remoto.

- **Diseñados para trabajar de manera conjunta.**

Principios Básicos de la Confianza Cero

- La empresa **supervisa y mide la integridad y la postura de seguridad de todos los activos** propios y de los asociados o empleados (ningún activo es intrínsecamente confiable).
- **Toda comunicación debe protegerse** independientemente de la ubicación de la red (interna o externa).
- El **acceso a los recursos** individuales de la empresa se concede por sesión (**evaluación de confianza y privilegios mínimos**).
- La **política** de acceso a los recursos debe ser **dinámica** e incluir:
    - Estado de la identidad del cliente,
    - Estado de la aplicación o servicio,
    - Estado del activo solicitante (versión de software instalada, hora y fecha de solicitud, comportamiento presentado previamente, etc.).
- Toda **autenticación y autorización se aplica de forma estricta** antes de permitir el acceso (la empresa debería contar con herramientas de IAM y sistemas de gestión de activos).
- La empresa **recopila toda la información posible sobre el estado actual** de los activos, la infraestructura de la red y las comunicaciones, y la utiliza para mejorar la postura de seguridad.

Actividad

- Por equipos, se asignará alguna de las siguientes tareas:
  - Investiga al menos 3 alternativas de soluciones IAM. Incluye:
    - Características principales
    - Costos (si se proporciona el dato).
  - Investiga al menos 3 alternativas de soluciones NAC. Incluye:
    - Características principales
    - Costos (si se proporciona el dato).
- Presenta una tabla comparativa y comenta los resultados

Servicios de Directorio Corporativos

Servicios de Directorio Corporativos

Almacenan cuentas de usuario, grupos y permisos de recursos en toda la red, con requisitos de seguridad específicos para cada enfoque de implementación.

LDAP (Lightweight Directory Access Protocol)

- Permite buscar, gestionar y autenticar información de usuarios, contraseñas, grupos y dispositivos de forma centralizada en una red.
- Almacén de credenciales centralizado.
- Puertos TCP 389 (sin cifrar) y 636 (cifrado mediante LDAPS)
- Utiliza nombres distintivos para identificar objetos dentro de una estructura de árbol de directorios.
- Las aplicaciones se conectan mediante credenciales almacenadas en el directorio.
- Requiere un servidor local.
- Requiere controles de seguridad externos para el cifrado y la gestión de accesos.

Controles de Seguridad LDAP

- Listas de control de acceso para restringir las consultas de directorio a aplicaciones autorizadas
- Políticas de contraseña con requisitos de complejidad e historial.
- Auditoría de directorios para intentos de autenticación.
- Procedimientos de copia de seguridad y recuperación de datos del directorio.
- Aplicación de canales seguros y protección de credenciales

Active Directory (AD)

Características Principales

- Implementa LDAP junto con las extensiones propietarias de Microsoft para administrar dominios de Windows.
- Los **controladores de dominio** gestionan las solicitudes de autenticación, mantienen la replicación del directorio y aplican las políticas de seguridad en todos los sistemas miembros.
- Ofrece directivas de seguridad, instalación de software y configuración del sistema mediante **Objetos de Directiva de Grupo (GPO)**.
- Control de seguridad centralizado.
- Requiere servidores controladores de dominio locales.
- Integra autenticación Kerberos:
    - Se emiten tickets de duración limitada, que los clientes presentan para acceder a los recursos.
    - El tráfico de red comprometido revelaría los tickets, no las contraseñas.

Seguridad y Alternativas

- Incluye políticas de seguridad integradas, pero concentra el riesgo en los controladores de dominio.
- Modelo de niveles administrativos (controladores de dominio, servidores, estaciones de trabajo).
- Grupos de usuarios protegidos para cuentas con altos privilegios.
- Comprobaciones periódicas del estado de AD.
- Alternativa en Software libre: Samba
    - Implementación libre del protocolo SMB (Server Message Block).
    - Permite que computadoras Windows se conecten a redes Linux.
    - Permite compatibilidad de archivos e impresoras entre servidores Linux y clientes Windows.

Entra ID (antes Azure Active Directory)

Características Principales

- Plataforma de identidad nativa en la nube de Microsoft.
- Compatibilidad con LDAP.
- Protocolos OAuth 2.0, SAML y OpenID Connect para integración de aplicaciones modernas.
- Admite múltiples flujos de autenticación, incluyendo opciones sin contraseña, autenticación multifactor y acceso condicional basado en riesgos.
- Gestión de identidades privilegiadas para asignación de roles administrativos.
- Protección de identidad para detección y respuesta automatizada de riesgos.
- Las decisiones de autenticación incorporan:
    - la confianza en el dispositivo,
    - el análisis de ubicación y
    - las señales de comportamiento (p. ej., puntuaciones de riesgo del usuario).

Gestión de Políticas y Entornos Híbridos

- Las decisiones de acceso incorporan información actualizada sobre amenazas y análisis de comportamiento.
- Proporciona administración de directivas nativa en la nube para dispositivos, independientemente de su pertenencia a un dominio o ubicación de red.
- Las directivas en la nube se aplican en el momento de la autenticación, lo que permite tomar decisiones de acceso en tiempo real basadas en los factores de riesgo actuales.
- En entornos híbridos, es posible sincronizar los directorios Active Directory con directorios en la nube, con el fin de habilitar el inicio de sesión en todos los entornos.
- Reduce los requisitos de infraestructura local, pero genera dependencia de la conectividad a internet y la disponibilidad del servicio en la nube.
- Soluciones alternativas:
    - Okta,
    - JumpCloud,
    - Keycloak (de código abierto, por RedHat),
    - Authentik/Authelia (ligera y de código abierto), entre otras.

Casos de Uso de los Servicios de Directorio

Autenticación de Aplicaciones

- Aplicaciones web integradas con servicios de directorio mediante enlaces LDAP, aserciones SAML o tokens OAuth.
- Aplicaciones modernas admiten Federación de identidades en la nube.
- Las aplicaciones deben conectarse a los servicios de directorio mediante cuentas de servicio con privilegios mínimos, en lugar de credenciales de usuario.

Inicio de Sesión Único (SSO)

- Se implementa mediante la federación de servicios de identidad con proveedores de identidad de aplicaciones.
- Permite a los usuarios autenticarse una sola vez y acceder a múltiples aplicaciones sin tener que volver a introducir sus credenciales.
- Reduce la proliferación de contraseñas.

Federaciones de Identidad

Sistema de confianza entre distintas organizaciones o dominios. Permite a un usuario autenticado en su empresa (o proveedor de identidad), acceso a distintos servicios sin registrarse de nuevo.

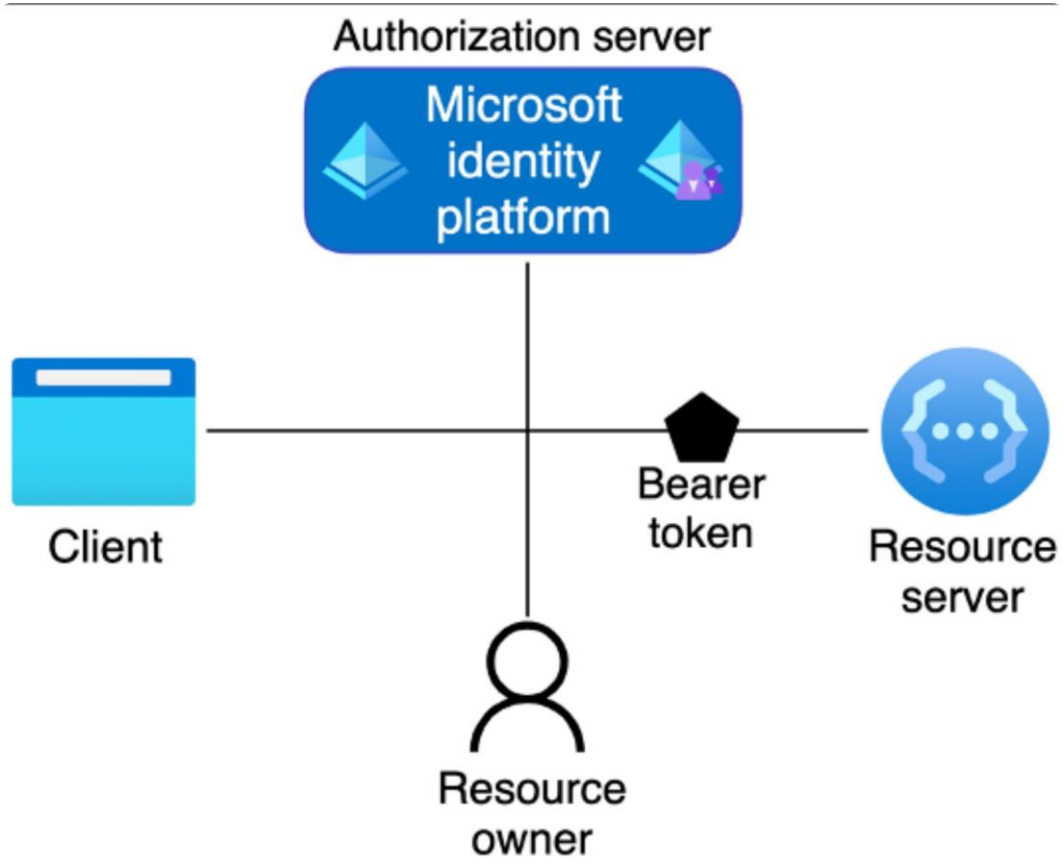
Single Sign-On (SSO)

- Mecanismo para el funcionamiento de la federación de identidades.

OAuth (Open Authorization)

- Estándar tecnológico que permite autorizar a una aplicación o servicio iniciar sesión en otra sin divulgar información privada, como contraseñas.
- Permite especificar a qué datos puede acceder el tercero y qué puede hacer con esos datos.
- Usa tokens de acceso para permitir interactuar con otro servicio en nombre del usuario.
- Un **token de acceso** es un fragmento de datos que contiene información sobre el usuario y el recurso para el que está pensado el token.
- Un token incluye **reglas específicas para el uso compartido de datos.**

Flujos de Autenticación OAuth: Componentes



Componentes del Flujo OAuth

- **Servidor de autorización o Proveedor de identidad (IdP)**:
  - **Controla** de forma segura la **información del usuario final, su acceso y las relaciones de confianza** entre las partes en el flujo de autenticación.
  - **Emite los tokens de seguridad** que las aplicaciones y las API usan para conceder, denegar o revocar el acceso a los recursos (autorización) después de que el usuario ha iniciado session (autenticación).
- **Cliente**: Aplicación que solicita acceso a un recurso protegido.
- **Propietario del recurso**: Usuario de la aplicación o el usuario final.
  - "Posee" el recurso protegido (sus datos) al que accede la aplicación en su nombre.
  - Pueden conceder o denegar a la aplicación (al cliente) acceso a los recursos que posee.
- **Servidor de recursos**:
  - Hospeda o proporciona acceso a los datos del propietario de un recurso.
  - Generalmente es una API web (programa que permite que dos programas se comuniquen entre sí a través de internet).
  - Valida los tokens de portador (incluido en la petición de acceso del cliente)
    - Firma válida
    - Sin alteraciones
    - Vigencia
    - Emitido por un servidor de autenticación de confianza
    - Alcances o permisos

Tipos de Tokens en OAuth

Token o token de portador. Se usan de 3 tipos:

Token de Acceso

- Contiene los permisos que el servidor de autorización ha concedido al cliente.
- El servidor de autorización emite tokens de acceso a la aplicación cliente.
- El cliente pasa tokens de acceso al servidor de recursos para su validación.

Token de Identificador

- El servidor de autorización emite tokens de identificador a la aplicación cliente.
- Los clientes usan tokens de identificador al iniciar la sesión de los usuarios y para obtener información básica sobre ellos.

Tokens de Actualización

- El cliente usa un token de actualización para solicitar nuevos tokens de acceso e identificador desde el servidor de autorización.

Registro de Aplicación

- Para que la aplicación pueda confiar en los tokens de seguridad, debe haber una relación de confianza con el IdP.
  - Se debe registrar la aplicación en el IdP.
  - Asignación de ID.
  - URI de redirección, para redirigir al destino correspondiente después de autenticarse en el IdP.

OpenID Connect (OIDC)

Funcionamiento de OAuth 2.0 y OpenID Connect (OIDC)

Descripción

- Es un protocolo de autenticación que verifica la identidad de un usuario cuando un usuario intenta acceder a un endpoint protegido del protocolo de transferencia de hipertexto seguro (HTTPS).
- Desarrollada por OpenID Foundation, que incluye empresas como Microsoft y Google. Debido a que OIDC proporciona autenticación y autorización.

Diferencias clave con OAuth

- OAuth se usa para conceder una autorización de acceso a los recursos
- OIDC se usa para la autenticación de la identidad de una persona
- OAuth es un estándar abierto para la autorización, mientras que OIDC es un estándar abierto para la autenticación.
- OIDC mejora las funcionalidades de OAuth 2.0
- Permite verificar la identidad al utilizar OAuth

Tokens de Identidad (ID)

- Se generan para un cliente en particular
- Incluyen detalles como: nombre de usuario, dirección de correo electrónico, fecha de nacimiento, tiempo de vencimiento, entre otros.
- Se pueden cifrar y firmar digitalmente.
- Solo se pueden obtener cuando el usuario le da a un cliente explícitamente acceso a cualquier información que requiera.

Tokens de Identidad y Proveedores (OIDC)

Tres funciones principales (similares a OAuth pero con diferentes términos)

Parte dependiente

Aplicación que solicita autenticación de usuario (aplicación cliente en OAuth)

Usuario final

Usuario cuya identidad se está verificando (propietario del recurso en OAuth)

Proveedor de OpenID

Servicio de OAuth configurado para habilitar OpenID Connect.

Proveedores de Identidad (IdP) dominantes

Entorno empresarial	Entorno de desarrollo	Entorno de Identidad Social
Microsoft Entra ID, Okta, Ping Identity, Google Workspace Identity.	Auth0 (propiedad de Okta), AWS Cognito.	Google, Apple, Meta (Facebook Login)

Mitigación de riesgos, gobernanza y factor humano

Vectores de Ataque a la Identidad

Robo de contraseñas

Ingeniería social

Principalmente a través de Phishing

Ataques de Interceptación (Man-in-the-Middle)

Malware de robo de credenciales

SIM Swapping

El atacante suplanta la identidad de la víctima y logra transferir su número telefónico a otra tarjeta SIM, argumentando robo o daño al dispositivo.

Credential Stuffing

El atacante utiliza listas de usuarios y contraseñas, generalmente obtenidas de filtraciones de datos previas, para automatizar (bots) el intento de inicio de sesión en diferentes sitios o servicios.

Vectores de Ataque Relacionados con Zero Trust

Vulnerabilidades a la segmentación basada en identidad

Si se logra comprometer una identidad, el atacante podría moverse lateralmente, en entornos supuestamente segmentados (físicamente).

Desviación de políticas y problemas de configuración

Las organizaciones se adaptan gradualmente a los cambios acelerados en las necesidades del negocio.

Se pueden realizar excepciones bienintencionadas en las políticas de seguridad, lo cual genera vulnerabilidades.

Dependencias de identidad de la cadena de suministro

La implementación de Zero Trust depende de múltiples proveedores de identidad y servicios en la nube.

Se crean redes complejas de relaciones de confianza que los atacantes pueden explotar mediante ataques a la cadena de suministro.

Técnicas de Grupos APT

Amenazas Persistentes Avanzadas (APT)

- Ciberataque oculto, prolongado y que permanece sin ser detectado por largo tiempo.
- Generalmente patrocinado por los estados con fines de ciberespionaje.

Vishing (o phishing por voz)

Método principal de acceso inicial. Potenciado por la IA generativa.

Suplantación de identidad en el servicio de asistencia técnica

Para generar un restablecimiento de contraseña o que el usuario eluda el MFA.

Operaciones de intermediarios de acceso

Venta de credenciales robadas.

Recomendaciones ante Amenazas a la Identidad

Modelo de Seguridad Zero Trust

- “Nunca confiar, siempre verificar”
- Ningún usuario, dispositivo o aplicación debería ser confiable por defecto.

Control de Acceso Basado en Roles (RBAC)

Autorización del acceso del usuario final a sistemas, aplicaciones y datos, basado en el rol predefinido del usuario.

Ejemplos:

- Un analista de seguridad puede configurar un firewall pero no puede ver los datos del cliente
- Un representante de ventas puede ver los datos del cliente, pero no puede tocar la configuración del firewall.

Control de Acceso Basado en Atributos (ABAC)

Permite establecer en función de diversos atributos:

- **Usuario**. El trabajo que puede realizar está determinado por: puesto de trabajo, tareas habituales, nivel de antigüedad.
- **Atributos del recurso**. Usa como criterios de acceso: tipo de archivo, persona que lo creó, confidencialidad del documento.
- **Entorno**. El acceso se determina por: lugar desde donde la persona accede al archivo, hora del día o fecha del calendario.
- Ejemplos:
  - Si el usuario pertenece al departamento de contabilidad, podrá acceder a los archivos contables.
  - Si la persona es un gerente, entonces esa persona puede leer/escribir archivos.
  - Si la política de la empresa especifica "no se trabaja los sábados" y hoy es sábado, entonces nadie podrá acceder a ningún archivo hoy.

Recomendaciones ante Amenazas a la Identidad (cont.)

Uso de Autenticación Multifactor

- No se recomienda MFA basada en el uso de SMS:
  - mensajes no cifrados,
  - vulnerables a SMS Swapping.
- Uso de Passkey FIDO.
  - Principalmente con llaves físicas (otras alternativas: OTP, gestores de contraseñas o autenticación biométrica)

Gestión de la Postura de Seguridad de la Identidad (ISPM)

- Uso del marco de trabajo y herramientas de Gestión de la Postura de Seguridad de la Identidad (ISPM, por sus siglas en inglés)
- Capacidades:
  - Monitoreo y análisis continuo de la actividad de la identidad para detectar anomalías
  - Identificar vulnerabilidades y deficiencias, prevenir el acceso accidental y con privilegios excesivos
  - Detectar riesgos como cuentas inactivas, administradores ocultos y ataques de Credential Stuffing.
  - Se pueden integrar con herramientas IAM, a través de API o como módulos

Referencias

1. Bcdiploma (s/f). Certificados Digitales: Guía Completa, Tipos y Ejemplos | BCdiploma. https://www.bcdiploma.com/es/blog/what-are-digital-certificates-the-complete-guide-to-security-trust-online
2. Bradley, S. M. E. I., reviewed by David John. (2026, septiembre 22). LDAP, Active Directory, and Entra ID: Directory Services for Security Teams. SC Media. https://www.scworld.com/tech-explainer/ldap-active-directory-and-entra-id-directory-services-for-security-teams
4. Cisco. (s/f). NAC explained: Control who connects to your network [Guide]. https://www.cisco.com/site/us/en/learn/topics/security/what-is-network-access-control-nac.html
5. DigiCert. (s/f). ¿Qué es la firma de código?. https://www.digicert.com/es/faq/code-signing-trust/what-is-code-signing
6. Dong, H., Zhang, Y., Lee, H., Du, K., Tu, G., & Sun, Y. (2024). Mutual TLS in Practice: A Deep Dive into Certificate Configurations and Privacy Issues. Proceedings of the 2024 ACM on Internet Measurement Conference, IMC '24, 214–229. https://doi.org/10.1145/3646547.3688415
7. Forrest, M. K., Amber. (2025, agosto 26). ¿Qué es la gestión de identidad y acceso (IAM)? | IBM. https://www.ibm.com/mx-es/think/topics/identity-access-management
8. Fortinet (s/f). ¿Qué son los certificados digitales?. https://www.fortinet.com/lat/resources/cyberglossary/digital-certificates.html
9. Fortinet. (s/f). ¿Qué es el control de acceso a la red (NAC)?. https://www.fortinet.com/lat/resources/cyberglossary/what-is-network-access-control.html
10. Fortinet. (s/f). ¿Qué es OpenID Connect (OIDC)? ¿Cómo funciona la autenticación OIDC?. https://www.fortinet.com/lat/resources/cyberglossary/oidc.html
11. Gupta, D. (2026, octubre 4). Map Before You Buy: The 2026 Identity Market After the Consolidation Wave. Security Boulevard. https://guptadeepak.com/identity-market-map-2026/
12. Heath, D. (2024, septiembre 25). La evolución de la confianza cero y los marcos que la guían | IBM. https://www.ibm.com/mx-es/think/insights/the-evolution-of-zero-trust-and-the-frameworks-that-guide-it
13. Hepp, S. (2025, diciembre 16). Ciclo de vida de JML: Pasos clave para una gestión de acceso adecuada. https://cloudviewpartners.com/jml-lifecycle/
14. Kosinski, G. L., Matt. (2025, mayo 2). ¿Qué es el control de acceso basado en roles (RBAC)? | IBM. https://www.ibm.com/mx-es/think/topics/rbac

Referencias (cont.)

15. Kosinski, J. H., Matthew. (2025, junio 18). ¿Qué es la identidad digital? | IBM. https://www.ibm.com/mx-es/think/topics/digital-identity
16. Kosinski, M. (2026, julio 24). ¿Qué es la autenticación sin contraseña? | IBM. https://www.ibm.com/mx-es/think/topics/passwordless-authentication
17. Microsoft Learn. (s/f). Protocolos de OAuth 2.0 y OpenID Connect—Microsoft identity platform. https://learn.microsoft.com/es-es/entra/identity-platform/v2-protocols
18. Microsoft Learn. (s/f). Trusted Platform Module Technology Overview. https://learn.microsoft.com/en-us/windows/security/hardware-security/tpm/trusted-platform-module-overview
19. Okta. (s/f). RBAC vs. ABAC: Definitions & When to Use. https://www.okta.com/identity-101/role-based-access-control-vs-attribute-based-access-control/
20. Pimentel, B. (2025, marzo 20). Digital identity: An overview. Thomson Reuters Law Blog. https://legal.thomsonreuters.com/blog/overview-digital-identity/
21. SANS Institute. (2025, octubre 27). Identity-Based Attacks: The Evolution from Social Engineering to Zero Trust Attack Vectors. https://www.sans.org/blog/identity-based-attacks-evolution-social-engineering-zero-trust-attack-vectors
22. Wireless Logic (s/f). Gestionar la identidad de los dispositivos es clave para implementaciones de IoT seguras y escalables. https://wirelesslogic.com/es/blog/gestionar-la-identidad-de-los-dispositivos-es-clave-para-implementaciones-de-iot-seguras-y-escalables